ISSUE 日本語解説資料

Issue #11 セキュリティ ベースラインを定義する

GitHub で closed になっている issue 記録を、そのまま参照用 PDF に変換したもの。

Issue #11　更新: 2026/03/08　ソース: docs/portal/issues/issue-11-security-baseline.md

GitHub: https://github.com/PLAYER1-r7/MultiCloudProject/issues/11

計画　portal　セキュリティ

この ISSUE の要点

HTTPS、CORS、シークレット管理、WAF、監査ログなどを後付けにすると、MVP 後に安全性の穴が残る。

目標

初期実装で外してはいけないセキュリティ基準を定義する。

完了状態

[docs/portal/13_SECURITY_BASELIN (docs/portal/13_SECURITY_BASELIN を security judgment の同期先として扱う

1. この Issue が扱っていたこと

まず Summary と Goal から、この Issue が何を決めるためのものだったかを短く押さえる。

HTTPS、CORS、シークレット管理、WAF、監査ログなどを後付けにすると、MVP 後に安全性の穴が残る。

目標

初期実装で外してはいけないセキュリティ基準を定義する。

2. 完了判断の見方

Tasks、Definition of Done、Current Status の記述から、どこまで完了済みとして扱っているかを先に読む。

TASKS

7/7 項目が完了済みとして記録されている。

DEFINITION OF DONE

7/7 項目が完了済みとして記録されている。

> docs/portal/13_SECURITY_BASELINE_DRAFT.md を security judgment の同期先として扱う / local issue file には task contract、discussion draft、resolution、evidence mapping、final review result を追加済み / HTTPS redirect、baseline headers、minimal CORS、managed secrets、auditability を first-release 必須 control として確定した / WAF は first-release 必須要件にはせず、非採用理由と再評価条件を残す方針で確定した / CI/CD secret の正規経路は approved GitHub Environment とし、staging と production の secret boundary は別 environment で分離する方針で確定した / runtime secret は必要時に managed store へ分離し、secret source ごとに rotation path を持つ方針で確定した / staging と production の header baseline は揃えることを目標とし、support gap は記録するが production を弱めない方針で確定した / first-release の最低 audit evidence は GitHub workflow history と cloud-native audit

> log の両方を参照可能にする方針で確定した / final checkbox review は完了し、Tasks と Definition of Done は満了と判断した

3. 依存関係と読み進め方

Dependencies や前提 Issue がある場合は、ここで関連先を先に把握しておくと読みやすい。

依存関係

- Issue 4
- Issue 7
- Issue 9
- Issue 10

読み方の注意

この解説書は原文の意思決定や完了状態を読みやすくするための補助資料である。最終的な正本は原文 Issue にあり、判断変更時は原文側を先に更新する。

4. 用語集

原文に残る英語や実務用語のうち、訳し切らずに補助説明を付けた方が読みやすい語をここにまとめる。

原語	日本語の扱い	補足
baseline	基準線	後続作業が参照する最小限の判断・実装・検証の出発点。
hardening	堅牢化	既存機能を壊れにくくし、運用や検証の安全性を高める作業。
staging	ステージング	本番前に動作や反映を確認するための検証環境。
production	本番環境	実際の利用者に公開される運用環境。
operator	運用担当者	監視、承認、非表示、切り戻しなどの運用行為を担う役割。
workflow	ワークフロー	GitHub Actions などで定義された自動処理の流れ。
owner	責任者	意思決定または更新責任を持つ担当者。文脈により product owner などを含む。
review	レビュー	内容や実装が要件を満たすか確認する工程。
evidence	証跡	判断や完了状態の根拠になるログ、表、文書、出力結果。
mapping	対応付け	チェック項目とその根拠を結び付けて整理すること。
draft	下書き	まだ確定前だが議論やレビューの基礎として置かれた文書。
release	リリース	利用者に公開するまとまりとしての提供単位。

原語	日本語の扱い	補足
rollback	ロールバック	変更後の状態から以前の安定状態へ戻すこと。
close approval	クローズ承認	Issue を完了扱いとして閉じてよいという明示承認。
current status	現在の状態	Issue 文書時点での完了度合いや同期状況を示す節。
definition of done	完了条件	その Issue を完了とみなすために満たすべき条件。
task contract	タスク契約	対象、目的、スコープ、検証計画、リスクを明文化した作業契約。

5. 原文

以下に Issue 原文をそのまま掲載する。詳細な根拠、証跡、チェックリストはこの原文を参照する。

概要

HTTPS、CORS、シークレット管理、WAF、監査ログなどを後付けにすると、MVP 後に安全性の穴が残る。

目標

初期実装で外してはいけないセキュリティ基準を定義する。

タスク契約

```
タスク契約

メタデータ
- タスク ID: ISSUE-11
- タイトル: セキュリティベースラインの初期整理
- 依頼者: repository owner
- 担当者: AI agent
- 対象アプリ: portal-web
- 対象環境: planning
- 優先度: 高

目的
- 解決する問題: public-first な初回リリースで後付けにすると危険な security control を先に固定し、実装段階での安全基準の欠落を防ぐ
- 期待する価値: Issue 10 の CI/CD gate と整合した secret 管理、header、CORS、audit、WAF の前提を作り、Issue 12 と Issue 14 の判断軸を安定させる

スコープ
- 含むもの: HTTPS、CORS、security headers、WAF 要否、secret 管理、audit/logging、first-release security checklist の議論たたき台
- 含まないもの: 実 WAF 導入、cloud account 設定変更、secret rotation 実施、実 workflow 実装、incident response 手順の詳細化
- 編集可能パス: docs/portal/issues/issue-11-security-baseline.md
- 制限パス: apps/, infra/, .github/workflows/

受け入れ条件
- [x] 条件 1: 初回リリースで必須とする security baseline が control ごとに整理され、Issue 10・12・14 の判断基準として参照できる状態になっている

実装計画
- 変更見込みファイル: docs/portal/issues/issue-11-security-baseline.md
- アプローチ: docs/portal/13_SECURITY_BASELINE_DRAFT.md、Issue 10 の CI/CD policy、docs_agent の critical guardrails を束ね、first-release scope に必要な security baseline を issue ローカルの議論記録へ整理する
- 採用しなかった代替案と理由: 実装手段や cloud-product 選定まで先に確定する案は、まだ policy と gate の段階で詰めるべき論点を隠しやすいため採らない

検証計画
- 実行するテスト: git status --short; GH_PAGER=cat gh issue view 11 --repo PLAYER1-r7/MultiCloudProject --json number,state,title,updatedAt,url
- 確認するログ/メトリクス: TBD
- 失敗時の切り分け経路: docs/portal/13_SECURITY_BASELINE_DRAFT.md、Issue 10、docs_agent/14_CRITICAL_GUARDRAILS_EXTRACT.md に戻り、first-release scope と production guardrail を混同していないかを確認する

リスクとロールバック
- 主なリスク: 初回リリースに不要な強度まで一気に確定し、MVP の delivery を不必要に重くすること
- 影響範囲: CI/CD secret posture、header 方針、CORS、audit、Issue 12 の monitoring、Issue 14 の rollback 前提
- 緩和策: public static portal に必要な baseline を優先し、将来強化項目は tracked gap として分ける
- ロールバック手順: security baseline が過剰または曖昧と判明した場合は、first-release 必須 control と later-phase hardening を再分離して整理し直す
```

作業項目

- [x] HTTPS 強制方針を定義する
- [x] CORS 制御方針を定義する
- [x] セキュリティヘッダ方針を定義する
- [x] WAF の要否を整理する

- [x] シークレット管理方針を定義する
- [x] 監査ログ方針を定義する
- [x] セキュリティチェックリストを作成する

完了条件

- [x] HTTPS 強制の方針と適用箇所が明示されている
- [x] CORS の適用範囲と最小化方針が説明されている
- [x] セキュリティヘッダの基本方針が整理されている
- [x] シークレットをリポジトリとフロントエンドから排除する方針が明記されている
- [x] 監査や変更履歴の追跡方針が説明されている
- [x] WAF の要否判断が明示されている
- [x] 初期実装で外してはいけない項目のチェック観点として参照できる

Issue 11 Discussion Draft

このセクションは、Issue 11 の議論を始めるためのたたき台である。Issue 10 により、staging は main 起点の review 済み commit から進め、production は explicit approval、restricted secrets、state locking gate、operator-managed external DNS/certificate cutover を前提にすることが整理された。したがって Issue 11 の論点は「強い security を何でも先に積むこと」ではなく、「初回リリース時点で欠けていると危険な baseline を delivery path と運用境界に沿って固定すること」である。

1. 現時点の前提整理

- 初回リリースは public-first、static-first portal であり、custom API と application persistence は前提にしない
- CI/CD は GitHub Actions を標準 path とし、staging と production で権限、gate、secret の扱いが分かれる
- docs_agent の critical guardrails では HTTPS、security headers、managed secrets、audit logging、no wildcard CORS in production を baseline として扱っている
- production はまだ guarded path であり、state locking、rollback target、external DNS/certificate coordination が gate 条件として残っている
- よって first-release security baseline は application code 内の複雑な access control よりも、delivery layer、CI/CD controls、secret posture、auditability を優先して整理する必要がある

2. 今回まず固定したい security baseline の分離軸

提案:

- browser-facing controls と operator-facing controls を分ける
- first-release で必須の control と later-phase hardening を分ける
- static site delivery の baseline と API 導入後に再評価すべき control を分ける
- staging safety rule と production gate rule を分ける

この切り分けを採る理由:

- HTTPS、headers、secret posture、audit trail は初回から必要だが、WAF の強度や detailed CORS matrix は architecture の変化に応じて段階化した方が実用的である
- CI/CD の secrets と approval trail は application 実装とは別の control なので、同じセクションで曖昧にしない方が後続 issue に引き継ぎやすい

3. HTTPS 強制方針のたたき台

提案:

- すべての public entry は HTTPS を正規経路とする
- HTTP は配信レイヤで HTTPS redirect する
- first-release の certificate は AWS baseline architecture に従い ACM 管理を前提にする

現時点の第一案:

- staging と production の両方で HTTPS redirect を baseline とする
- external DNS を使う production では、certificate validation と cutover は operator-managed step であることを前提に security baseline へ含める
- missing HTTPS enforcement は cosmetic issue ではなく release blocker として扱う

4. CORS 制御方針のたたき台

提案:

- first-release で custom API が存在しない限り、CORS exposure は最小または不要に留める
- future convenience のための wildcard CORS は許可しない
- API-backed interaction を導入した時点で cloud-specific な CORS control を再評価する

現時点の第一案:

- portal-web の first-release scope では broad CORS policy を前提にしない
- production では wildcard CORS を禁止する
- staging でも production を弱める方向の permissive setting は先に入れない

5. Security Header 方針のたたき台

提案:

- security headers は delivery layer で明示的に管理する
- baseline header set は HSTS、CSP、X-Content-Type-Options、X-Frame-Options、strict referrer policy を中心にする
- one cloud path lacks support の場合は tracked gap として扱い、他環境を弱めて合わせない

現時点の第一案:

- first-release static portal では app code の ad hoc 実装よりも CDN または配信レイヤ設定を正規経路とする
- CSP は過度に複雑化させず、first-release の asset/source model に合う conservative policy から始める

6. WAF 要否のたたき台

提案:

- public static informational release では WAF を自動的な必須要件とはしない
- ただし WAF 不採用を implicit にせず、理由と再評価条件を残す
- traffic profile、compliance、protected interaction の変化があれば WAF posture を再評価する

現時点の第一案:

- first-release では `mandatory now` ではなく `documented decision` として扱う
- AWS path では CloudFront WebACL を将来の第一候補として記録する
- WAF 未導入でも HTTPS、headers、managed secrets、audit trail は省略しない

7. Secret 管理方針のたたき台

提案:

- secrets は repository と frontend bundle に置かない
- CI/CD secret の正規経路は approved GitHub Environment とし、runtime secret が必要になった時点で managed secret store を追加する
- staging と production で secret scope と access path を分離する
- staging と production の CI/CD secret は別の approved GitHub Environment で分離する

Issue 10 との接続:

- staging には reviewer gate は置かないが、environment secret と deploy 権限は制御する
- production は explicit approval gate と secret access control を同時に満たす必要がある

現時点の第一案:

- build 時に frontend へ埋め込む値は public-only に限る
- production secret exposure が疑われる場合は feature work より先に rotate and invalidate を優先する
- secret source ごとに rotation path を持つ方針を baseline に含める

8. 監査ログ方針のたたき台

提案:

- deploy、infra change、security-relevant config change は traceable でなければならない
- repository history、workflow execution logs、cloud-native audit logs を組み合わせて reviewable にする

- audit logging は optional observability ではなく security investigation の基盤とする

現時点の第一案:

- first-release では最低でも GitHub workflow history と cloud-native audit log を有効な前提に置く
- retention を casual に削らない
- human approval と operator step は issue comment、workflow evidence、または execution record で追跡できるようにする

9. first-release security checklist のたたき台

初回リリース前に最低限確認したい項目:

- HTTPS redirect が有効
- repository と frontend bundle に secret がない
- baseline security headers が定義されている
- broad or wildcard CORS が有効化されていない
- WAF の採否と再評価条件が明示されている
- deploy と infra change の audit trail が追跡可能
- staging と production の secret scope と approval boundary が分離されている

10. Issue 10 / 12 / 14 への接続観点

- Issue 10 の production gate を security 観点から補強し、GitHub Environment と secret access control の要件を明示する
- Issue 12 では security-relevant failure notification と audit log の参照元を監視方針へ接続する
- Issue 14 では secret exposure、header misconfiguration、DNS/certificate rollback を復旧手順へ接続する

11. この場で確認したい論点

Question	Provisional direction (at draft time)	Resolution confirmed wording
first-release static portal で WAF を必須条件にするか	現時点では必須導入ではなく、非採用理由と再評価条件の明示を優先する	`first-release static portal` では `WAF` を必須導入条件としないが、非採用理由、再評価条件、将来の第一候補を明示する
CSP は first-release でどこまで厳しく固定するか	conservative baseline から始め、将来 asset/source model の変化に応じて強化する	`CSP` は `first-release` の `asset/source model` に合う `conservative baseline` から始め、`source` 追加時に明示的に更新する
staging に production 相当の security header 完全一致を求めるか	原則は一致を目指すが、platform support gap は tracked gap として扱う	`staging` と `production` は同じ `security header baseline` を目標とし、差分が残る場合は `support gap` として記録するが `production` を弱めて合わせない
secret 管理の正規経路を GitHub Environment のみで始めるか、cloud secret store まで初回から必須にするか	CI/CD secret は GitHub Environment を入口にし、runtime secret source は必要性に応じて分ける	`CI/CD secret` の正規経路は `approved GitHub Environment` とし、`runtime secret` が必要になった時点で `managed secret store` を追加し、`repository` と `frontend bundle` への埋め込みは許可しない
audit evidence は GitHub workflow history と cloud audit log のどこまでを最低条件とするか	first-release では両方を参照可能にし、少なくとも deploy と infra change は追跡可能にする	`first-release` の最低 `audit evidence` は `GitHub workflow history` と `cloud-native audit log` の両方を参照可能にし、少なくとも `deploy`、`infra change`、`approval`、`operator step` を追跡可能にする

Resolution

Issue 11 の判断結果は次の通りとする。

- first-release security baseline は public-first static portal に対して、HTTPS、baseline security headers、minimal CORS exposure、managed secrets、auditability を必須 control とする

- すべての public entry は HTTPS を正規経路とし、HTTP は配信レイヤで HTTPS へ redirect する
- missing HTTPS enforcement は cosmetic issue ではなく release blocker として扱う
- CORS は actual need に最小化し、first-release で custom API がない限り broad or wildcard policy を前提にしない
- production では wildcard CORS を許可せず、staging でも production を弱める方向の permissive setting を先行導入しない
- security headers は delivery layer で明示的に管理し、first-release baseline は HSTS、CSP、X-Content-Type-Options、X-Frame-Options、strict referrer policy を中心にする
- CSP は first-release の asset/source model に合う conservative baseline から始め、source 追加時に明示的に更新する
- staging と production は同じ security header baseline を目標とし、差分が残る場合は support gap として記録するが production を弱めて合わせない
- first-release static portal では WAF を必須導入条件としないが、非採用理由、再評価条件、将来の第一候補として AWS path の CloudFront WebACL を記録する
- secrets は repository と frontend bundle に置かず、CI/CD secret の正規経路は approved GitHub Environment とする
- staging と production の CI/CD secret は別の approved GitHub Environment で分離する
- runtime secret が必要になった時点で managed secret store を追加し、secret source ごとに rotation path を持つ
- production secret exposure が疑われる場合は feature work より先に rotate and invalidate を優先する
- first-release の最低 audit evidence は GitHub workflow history と cloud-native audit log の両方を参照可能にし、少なくとも deploy、infra change、approval、operator step を追跡可能にする
- audit logging は optional observability ではなく security investigation の基盤とし、retention を casual に削らない
- first-release の security checklist は HTTPS redirect、no repository secrets、baseline headers、minimal CORS、documented WAF decision、auditable deploy and infra change、separated staging and production secret boundaries を含む

この合意案で明確になること:

- Issue 10 の production gate は secret access control、auditability、operator step 記録の面から補強される
- Issue 12 は security-relevant notification と audit log 参照元を monitoring policy に接続できる
- Issue 14 は secret exposure、header misconfiguration、DNS/certificate rollback を rollback policy に接続できる
- 初回リリースでは WAF mandatory のような過剰要件を避けつつ、後付けが危険な baseline を先に固定できる

証跡対応表

The tables below identify the evidence used for final checkbox review and should remain aligned with the checked state above.

For Issue 11 final review, the local issue record is the primary evidence source. docs/portal/13_SECURITY_BASELINE_DRAFT.md is supporting background and synchronized policy text, not the sole proof of checklist completion.

作業項目対応表

Checklist item	Primary evidence section	Why this is the evidence	Review state
`HTTPS 強制方針を定義する`	`3. HTTPS 強制方針のたたき台`, `Resolution`, and docs/portal/13_SECURITY_BASELINE_DRAFT.md	These sections define HTTPS as the required public path, describe redirect behavior, and make missing enforcement a blocker.	Accepted for final review
`CORS 制御方針を定義する`	`4. CORS 制御方針のたたき台`, `Resolution`, and docs/portal/13_SECURITY_BASELINE_DRAFT.md	These sections define minimal exposure, prohibit speculative wildcard usage, and reserve broader CORS only for future API-backed interactions.	Accepted for final review
セキュリティヘッダ方針を定義する	`5. Security Header 方針のたたき台`, `11. この場で確認したい論点`, and `Resolution` in docs/portal/issues/issue-11-security-baseline.md	These sections define the baseline header set, delivery-layer responsibility, and how staging and production parity should be handled.	Accepted for final review

Checklist item	Primary evidence section	Why this is the evidence	Review state
WAF の要否を整理する	6. WAF 要否のたたき台, 11. この場で確認したい論点, and Resolution in docs/portal/issues/issue-11-security-baseline.md	These sections record that WAF is not mandatory for the first release, while still requiring explicit reasoning and reevaluation triggers.	Accepted for final review
シークレット管理方針を定義する	7. Secret 管理方針のたたき台, 10. Issue 10 / 12 / 14 への接続観点, and Resolution in docs/portal/issues/issue-11-security-baseline.md	These sections define GitHub Environment as the CI/CD secret path, separate staging and production secret boundaries, reserve managed stores for runtime needs, and prohibit repository or frontend embedding.	Accepted for final review
監査ログ方針を定義する	8. 監査ログ方針のたたき台, 11. この場で確認したい論点, and Resolution in docs/portal/issues/issue-11-security-baseline.md	These sections define the minimum audit evidence set and preserve audit logging as a non-optional security capability.	Accepted for final review
セキュリティチェックリストを作成する	9. first-release security checklist のたたき台 and Resolution in docs/portal/issues/issue-11-security-baseline.md	These sections collect the required first-release controls into a reviewable checklist for implementation and release readiness.	Accepted for final review

完了条件対応表

Checklist item	Primary evidence section	Why this is the evidence	Review state
HTTPS 強制の方針と適用箇所が明示されている	3. HTTPS 強制方針のたたき台, Resolution, and docs/portal/13_SECURITY_BASELINE_DRAFT.md	These sections define HTTPS redirect behavior and place it on the delivery path for both environments.	Accepted for final review
CORS の適用範囲と最小化方針が説明されている	4. CORS 制御方針のたたき台 and Resolution in docs/portal/issues/issue-11-security-baseline.md	These sections describe minimal exposure and explicitly reject permissive wildcard defaults.	Accepted for final review
セキュリティヘッダの基本方針が整理されている	5. Security Header 方針のたたき台, 11. この場で確認したい論点, and Resolution in docs/portal/issues/issue-11-security-baseline.md	These sections define the baseline header set and how parity and support gaps should be handled.	Accepted for final review
シークレットをリポジトリとフロントエンドから排除する方針が明記されている	7. Secret 管理方針のたたき台, Resolution, and docs/portal/13_SECURITY_BASELINE_DRAFT.md	These sections prohibit repository and frontend embedding while defining the approved control path for CI/CD secrets and separate staging and production secret boundaries.	Accepted for final review
監査や変更履歴の追跡方針が説明されている	8. 監査ログ方針のたたき台, Resolution, and docs/portal/13_SECURITY_BASELINE_DRAFT.md	These sections define the required evidence sources and preserve traceability for deploy and infra changes.	Accepted for final review

Checklist item	Primary evidence section	Why this is the evidence	Review state
WAF の要否判断が明示されている	6. WAF 要否のたたき台, 11. この場で確認したい論点, and Resolution in docs/portal/issues/issue-11-security-baseline.md	These sections explicitly record the first-release decision, non-adoption rationale, and reevaluation triggers.	Accepted for final review
初期実装で外してはいけない項目のチェック観点として参照できる	9. first-release security checklist のたたき台, 10. Issue 10 / 12 / 14 への接続観点, and Resolution in docs/portal/issues/issue-11-security-baseline.md	These sections organize the baseline into a reusable checklist and connect it to delivery, monitoring, and rollback work.	Accepted for final review

最終レビュー結果

Final checkbox review completed against the latest wording in docs/portal/issues/issue-11-security-baseline.md, with docs/portal/13_SECURITY_BASELINE_DRAFT.md used as synchronized supporting policy text. The table below records the document-level validation judgment. Human close approval remains a separate action.

Checklist area	Final judgment	Evidence basis
HTTPS baseline	Satisfied	3. HTTPS 強制方針のたたき台, Resolution, and docs/portal/13_SECURITY_BASELINE_DRAFT.md confirm HTTPS redirect and release-blocking treatment for missing enforcement.
Minimal CORS exposure	Satisfied	4. CORS 制御方針のたたき台 and Resolution confirm minimal exposure and no wildcard production posture.
Security header baseline	Satisfied	5. Security Header 方針のたたき台, 11. この場で確認したい論点, and Resolution confirm the baseline header set and parity rule.
Secret posture	Satisfied	7. Secret 管理方針のたたき台, Resolution, and docs/portal/13_SECURITY_BASELINE_DRAFT.md confirm approved secret paths, separate staging and production CI/CD secret boundaries, and prohibition on repository or frontend embedding.
Auditability	Satisfied	8. 監査ログ方針のたたき台, Resolution, and docs/portal/13_SECURITY_BASELINE_DRAFT.md confirm traceable deploy, infra, approval, and operator steps.
WAF decision	Satisfied	6. WAF 要否のたたき台, 11. この場で確認したい論点, and Resolution confirm that WAF is documented as not mandatory now, with reevaluation triggers retained.
First-release checklist readiness	Satisfied	9. first-release security checklist のたたき台, 10. Issue 10 / 12 / 14 への接続観点, and Resolution confirm that the baseline can be reused by downstream issues.

現在の状態

- docs/portal/13_SECURITY_BASELINE_DRAFT.md を security judgment の同期先として扱う
- local issue file には task contract、discussion draft、resolution、evidence mapping、final review result を追加済み
- HTTPS redirect、baseline headers、minimal CORS、managed secrets、auditability を first-release 必須 control として確定した
- WAF は first-release 必須要件にはせず、非採用理由と再評価条件を残す方針で確定した
- CI/CD secret の正規経路は approved GitHub Environment とし、staging と production の secret boundary は別 environment で分離する方針で確定した
- runtime secret は必要時に managed store へ分離し、secret source ごとに rotation path を持つ方針で確定した
- staging と production の header baseline は揃えることを目標とし、support gap は記録するが production を弱めない方針で確定した
- first-release の最低 audit evidence は GitHub workflow history と cloud-native audit log の両方を参照可能にする方針で確定した
- final checkbox review は完了し、Tasks と Definition of Done は満了と判断した

依存関係

- Issue 4
- Issue 7
- Issue 9
- Issue 10